

MAINCRAFTS TECHNOLOGY

Cybersecurity & Ethical Hacking Internship Program

THREAT INTELLIGENCE REPORT

Task 1 — Awareness & Research Project

Modern Cybersecurity Threat Landscape 2024–2025

Prepared by:

Pruthvi Panchal

B.E. Information Technology | Gujarat Technological University

Cybersecurity Analyst Intern (Simulation)

Date: 1 July 2026

Classification: UNCLASSIFIED | For Educational Use Only

Table of Contents

- 1. Executive Summary 3
- 2. Introduction to Cybersecurity 3
- 3. Threat Analysis**
 - 3.1 AI-Powered Phishing Attacks 4
 - 3.2 Ransomware-as-a-Service (RaaS) 5
 - 3.3 Cloud Security Misconfigurations 6
 - 3.4 IoT Vulnerabilities 7
 - 3.5 Zero-Day Exploits 8
- 4. Comparative Threat Overview 9
- 5. Conclusion & Future Scope 9
- 6. References 10

1. Executive Summary

This Threat Intelligence Report has been prepared as part of the MainCrafts Technology Cybersecurity & Ethical Hacking Internship Program (Task 1). The report covers the five most critical cybersecurity threats observed in 2024–2025, providing in-depth analysis of each threat vector, documented real-world incidents, measurable impact on individuals and organizations, and actionable defensive countermeasures.

The threat landscape has evolved dramatically with the proliferation of Artificial Intelligence, widespread cloud adoption, and an explosion of Internet-of-Things (IoT) devices. Threat actors now leverage these technologies to scale attacks that were previously limited to nation-state actors. This report aims to equip stakeholders with awareness and tactical knowledge to proactively defend digital assets.

2. Introduction to Cybersecurity

2.1 What is Cybersecurity?

Cybersecurity is the discipline of protecting computer systems, networks, programs, and data from digital attacks, unauthorized access, damage, or theft. It encompasses a broad set of technologies, processes, and practices designed to safeguard digital infrastructure and information assets from adversarial threats.

Modern cybersecurity operates across multiple domains including: Network Security, Application Security, Endpoint Security, Cloud Security, Identity & Access Management (IAM), and Security Operations (SecOps).

2.2 Why is Cybersecurity Important?

For Individuals:

- Protection of personal data (PII, financial records, health information)
- Prevention of identity theft, financial fraud, and account takeover
- Privacy preservation in an increasingly data-driven digital world

For Organizations:

- Safeguarding intellectual property, trade secrets, and customer data
- Maintaining business continuity and operational uptime
- Regulatory compliance (GDPR, DPDP Act 2023, RBI CSCR, HIPAA, PCI-DSS)
- Preserving brand reputation and customer trust
- Avoiding multi-million dollar breach costs (IBM 2024: avg. breach = \$4.88M)

2.3 Current Relevance — The 2024–2025 Threat Climate

- Cybercrime costs are projected to exceed \$10.5 trillion USD annually by 2025 (Cybersecurity Ventures)
- AI-driven attacks enable adversaries to scale phishing, deepfakes, and malware at unprecedented speed
- Supply chain attacks have become the preferred vector for nation-state actors
- India reported a 300% increase in cybercrime incidents between 2020–2024 (MHA Cyber Division)
- The global cybersecurity talent gap stands at 3.4 million unfilled positions, widening the attack surface

3. Threat Analysis

3.1. AI-Powered Phishing Attacks

AI-powered phishing represents the weaponization of Large Language Models (LLMs), deepfake audio/video, and social engineering automation to craft highly personalized and convincing deceptive communications. Unlike traditional phishing, AI enables attackers to generate context-aware emails, clone voices of executives in real-time, and bypass conventional spam filters with zero grammatical errors.

Impact Analysis:

- Individuals: Credential theft, financial fraud via banking impersonation, account takeover of social/email accounts
- Organizations: Business Email Compromise (BEC) leading to wire fraud, data exfiltration, executive impersonation (CEO fraud)
- Financial Impact: FBI IC3 2023 — BEC alone caused \$2.9 billion in losses in the US
- Operational: Phishing is the #1 initial access vector, responsible for 36% of all breaches (Verizon DBIR 2024)

📌 Case Study: WormGPT & FraudGPT (2023–2024)

In mid-2023, cybersecurity researchers identified WormGPT — an uncensored AI model trained on malware data, sold on darknet forums for \$200/month. Threat actors used it to generate highly convincing BEC emails indistinguishable from legitimate corporate communications. FraudGPT followed shortly after, specifically designed for phishing kits and carding. These tools democratized sophisticated social engineering for low-skill attackers.

Preventive Measures:

- Deploy AI-powered email security gateways (Microsoft Defender, Proofpoint, Mimecast) with anomaly detection
- Enforce Multi-Factor Authentication (MFA) — preferably hardware FIDO2 keys — to neutralize credential theft
- Conduct regular Security Awareness Training with simulated phishing campaigns (KnowBe4, Cofense)
- Implement DMARC, DKIM, and SPF email authentication protocols to prevent domain spoofing
- Establish out-of-band verification protocols for wire transfers and sensitive requests

3.2. Ransomware-as-a-Service (RaaS)

Ransomware-as-a-Service is a cybercriminal business model where ransomware developers lease their malware infrastructure, toolkits, and support to affiliates in exchange for a percentage of ransom proceeds (typically 20–30%). This model has industrialized ransomware attacks, enabling non-technical criminals to launch devastating campaigns. Modern RaaS operations feature customer support portals, negotiation services, data leak sites, and even SLA guarantees.

Impact Analysis:

- Individuals: Permanent loss of personal files, photos, documents; ransom demands ranging \$500–\$5,000
- Organizations: Average enterprise ransom demand reached \$2.73 million in 2024 (Sophos State of Ransomware Report)
- Operational Downtime: Average recovery time is 3–4 weeks, causing catastrophic business disruption
- Double Extortion: Attackers encrypt data AND threaten to publish it, compounding reputational damage
- Critical Infrastructure: Hospitals, pipelines, and utilities have been crippled by RaaS attacks

📄 Case Study: LockBit 3.0 & ALPHV/BlackCat (2022–2024)

LockBit 3.0 emerged as the most prolific ransomware group of 2023, responsible for over 1,000 confirmed attacks including Boeing, the Industrial & Commercial Bank of China (ICBC), and multiple hospitals. It operated a full RaaS affiliate program with a bug bounty for its own malware. ALPHV/BlackCat targeted MGM Resorts in 2023, causing \$100+ million in losses and 10 days of operational disruption. Despite law enforcement takedowns in 2024, both groups relaunched operations, demonstrating the resilience of RaaS ecosystems.

Preventive Measures:

- Maintain the 3-2-1-1-0 backup strategy: 3 copies, 2 media types, 1 offsite, 1 air-gapped, 0 errors verified
- Implement network segmentation and micro-segmentation to prevent lateral movement post-compromise
- Deploy Endpoint Detection & Response (EDR) solutions with behavioral analysis (CrowdStrike, SentinelOne)
- Apply Zero Trust Architecture — never trust, always verify, least-privilege access
- Disable RDP on internet-facing systems; enforce VPN with MFA for remote access

3.3. Cloud Security Misconfigurations

Cloud security misconfigurations occur when cloud resources (storage buckets, databases, compute instances, APIs) are set up with insecure default settings, overly permissive IAM policies, or lack of encryption. As organizations rapidly migrate to AWS, GCP, and Azure, misconfigured resources become publicly accessible, exposing sensitive data. This is consistently ranked as the #1 cloud security risk by CSA (Cloud Security Alliance).

Impact Analysis:

- Individuals: Exposure of personal data stored by organizations (healthcare records, financial data, PII)
- Organizations: Data breaches, regulatory fines (GDPR fines up to 4% of global annual revenue)
- Financial: The average cost of a cloud-related breach is \$4.75 million (IBM Cost of a Data Breach 2024)
- Compliance: HIPAA, PCI-DSS, and SOC 2 violations leading to legal liability
- Reputational: Public disclosure requirements under breach notification laws damage customer trust

📌 Case Study: Capital One Data Breach (2019)

In July 2019, a misconfigured AWS Web Application Firewall (WAF) allowed former AWS engineer Paige Thompson to exfiltrate data of over 100 million Capital One customers and applicants. The exposed data included names, addresses, credit scores, bank account numbers, and SSNs. Capital One paid \$80 million in OCC fines and \$190 million in class-action settlement. The breach highlighted the 'shared responsibility model' — AWS secures the cloud, customers secure what's in the cloud.

Preventive Measures:

- Continuously audit cloud configurations using CSPM tools (Wiz, Orca Security, AWS Security Hub, Prisma Cloud)
- Enforce least-privilege IAM policies; disable root account access; require MFA for all cloud console access
- Enable server-side encryption and enforce bucket/storage policies blocking public access by default
- Implement Cloud Infrastructure Entitlement Management (CIEM) to detect excessive permissions
- Conduct regular penetration testing of cloud environments and subscribe to cloud provider security advisories

3.4. IoT Vulnerabilities

The Internet of Things (IoT) encompasses billions of connected devices — smart cameras, industrial sensors, medical devices, routers, smart home systems, and wearables. IoT devices are inherently insecure due to resource constraints (no room for heavy security software), default credentials, infrequent patch cycles, and lack of encryption. Compromised IoT devices are weaponized into botnets, used as entry points into networks, and in critical infrastructure contexts, can cause physical harm.

Impact Analysis:

- Individuals: Surveillance via compromised smart cameras, smart home invasion, health data theft from wearables
- Organizations: IoT devices used as lateral movement entry points into enterprise networks
- Critical Infrastructure: Industrial IoT (IIoT) attacks on power grids, water treatment, and manufacturing
- Botnet Recruitment: Compromised IoT devices used for DDoS attacks (Mirai botnet: 620 Gbps attack on KrebsOnSecurity)
- Medical IoT: Vulnerabilities in pacemakers, insulin pumps pose life-threatening risks

📖 Case Study: Mirai Botnet & Volt Typhoon (2016–2024)

The Mirai botnet (2016) infected 600,000 IoT devices using default credentials (admin/admin, root/root), launching a 1.2 Tbps DDoS attack that took down major internet services including Netflix, Twitter, and GitHub. In 2024, CISA and FBI issued a joint advisory about Volt Typhoon, a Chinese nation-state APT that had pre-positioned in US critical infrastructure IoT and OT networks for 5+ years, demonstrating that IoT compromise is now a geopolitical weapon.

Preventive Measures:

- Change all default credentials immediately upon device deployment; use a password manager for device credentials
- Segment IoT devices on dedicated VLANs isolated from corporate networks with strict firewall rules
- Implement an IoT asset inventory and vulnerability management program; patch firmware regularly
- Deploy Network Access Control (NAC) to authenticate and monitor all IoT devices joining the network
- Prefer IoT devices from vendors with published security policies and regular CVE patching track records

3.5. Zero-Day Exploits

A zero-day vulnerability is a software flaw unknown to the vendor, for which no patch exists at the time of exploitation. Zero-day exploits represent the most dangerous class of attack — they cannot be blocked by signature-based defenses, and victims have zero days to prepare. Nation-state actors and well-funded criminal groups trade zero-days on darknet marketplaces for \$100,000–\$2.5 million per exploit (Zerodium pricing). In 2024, CISA tracked 168 actively exploited zero-days, a 17% increase from 2023.

Impact Analysis:

- Individuals: Account compromise via unpatched browser/OS vulnerabilities; mobile zero-days enabling silent surveillance (Pegasus spyware)
- Organizations: Total system compromise before vendor awareness; impossible to patch the unknown
- Supply Chain: Zero-days in widely-used libraries (Log4Shell affected 35,000+ Java applications globally)
- Nation-State Espionage: State-sponsored APTs use zero-days for long-term covert access to government systems
- Financial: A single zero-day attack can cost an organization \$250 million+ in remediation and lost business

📌 Case Study: Log4Shell (CVE-2021-44228) & MOVEit Transfer (CVE-2023-34362)

Log4Shell, disclosed in December 2021, was a critical RCE vulnerability in the Apache Log4j logging library — embedded in millions of Java applications. Within 72 hours of disclosure, over 800,000 exploitation attempts were logged globally. The CIOp ransomware group leveraged the MOVEit Transfer zero-day in 2023 to exfiltrate data from 2,700+ organizations including government agencies, universities, and banks, impacting 93 million individuals. MOVEit demonstrated how a single vendor vulnerability can trigger a mass-casualty breach event.

Preventive Measures:

- Implement a comprehensive Patch Management program — prioritize CISA's Known Exploited Vulnerabilities (KEV) catalog
- Deploy application allowlisting and runtime application self-protection (RASP) to block unknown exploit payloads
- Adopt a Defense-in-Depth strategy: multiple security layers ensure a single zero-day doesn't lead to full compromise
- Subscribe to threat intelligence feeds (CISA KEV, Mandiant, Recorded Future) for early zero-day disclosure alerts
- Conduct regular penetration testing and red team exercises to discover unknown vulnerabilities proactively

4. Comparative Threat Overview

The following table provides a high-level comparison of the five analyzed threats across key risk dimensions:

Threat	Severity	Primary Vector	Target	2024 Trend	Detection Difficulty
AI Phishing	Critical	Email / Social	All users	↑ 58% YoY	Very High
RaaS	Critical	RDP / Phishing	Enterprises	↑ 73% YoY	High
Cloud Misconfig	High	Cloud APIs	Cloud users	↑ 45% YoY	Medium
IoT Vulns	High	Default Creds	Smart devices	↑ 300% YoY	Very High
Zero-Day	Critical	Software Vuln	All systems	↑ 17% YoY	Extremely High

5. Conclusion & Future Scope

The 2024–2025 threat landscape is defined by sophistication, scale, and speed. Adversaries are no longer lone hackers — they operate as organized criminal enterprises and nation-state actors with resources rivaling those of legitimate corporations. The five threats analyzed in this report — AI-Powered Phishing, Ransomware-as-a-Service, Cloud Security Misconfigurations, IoT Vulnerabilities, and Zero-Day Exploits — represent the most impactful attack vectors currently threatening individuals, enterprises, and critical national infrastructure.

The convergence of AI with offensive security tools is perhaps the most alarming trend. As LLMs become more capable, the cost of launching highly sophisticated attacks approaches zero, while defenders must maintain vigilance across an ever-expanding attack surface. This asymmetry demands a shift from reactive, signature-based defenses to proactive, intelligence-driven security operations.

Key Takeaways

- No single technology or tool provides complete protection — Defense-in-Depth is non-negotiable
- Human error remains the weakest link; security awareness training is a foundational investment
- Threat intelligence sharing between organizations, ISACs, and government agencies accelerates detection
- The shift to Zero Trust Architecture eliminates implicit trust and limits blast radius of any breach
- Continuous monitoring, red teaming, and tabletop exercises build organizational cyber resilience

Future Scope

Emerging threat vectors that security professionals must prepare for in 2025–2026 include: Quantum Computing attacks on current encryption standards (NIST Post-Quantum Cryptography standards becoming critical), AI vs. AI warfare (defensive AI systems battling adversarial AI in real-time), attacks on Large Language Models themselves (prompt injection, data poisoning), and the increasing targeting of satellite communications and space infrastructure. Continuous learning, threat hunting, and community engagement (CTFs, bug bounties) remain the most effective tools for staying ahead of adversaries.

6. References

The following sources were consulted in the preparation of this report:

- IBM Security — Cost of a Data Breach Report 2024: <https://www.ibm.com/security/data-breach>
- Verizon — Data Breach Investigations Report (DBIR) 2024: <https://www.verizon.com/business/resources/reports/dbir/>
- CISA — Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- CISA — Cybersecurity Advisories: <https://www.cisa.gov/news-events/cybersecurity-advisories>
- Sophos — State of Ransomware Report 2024: <https://www.sophos.com/en-us/content/state-of-ransomware>
- OWASP — Top 10 Web Application Security Risks: <https://owasp.org/www-project-top-ten/>
- KrebsOnSecurity — Cybercrime News & Analysis: <https://krebsonsecurity.com/>
- Mandiant — M-Trends 2024 Threat Report: <https://www.mandiant.com/m-trends>
- ENISA — Threat Landscape Report 2024: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>
- FBI IC3 — Internet Crime Report 2023: https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf
- Cloud Security Alliance — Top Threats to Cloud Computing 2024: <https://cloudsecurityalliance.org/>
- NIST — National Vulnerability Database: <https://nvd.nist.gov/>
- Cybersecurity Ventures — Cybercrime Report 2025: <https://cybersecurityventures.com/>
- NVD — Log4Shell CVE-2021-44228: <https://nvd.nist.gov/vuln/detail/CVE-2021-44228>
- NVD — MOVEit Transfer CVE-2023-34362: <https://nvd.nist.gov/vuln/detail/CVE-2023-34362>

— End of Report —